

Chapitre 8

Étude de cas — cybermenaces et sécurité de l'information — corrigés

Corrigé

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Corrigés des exercices du chapitre

Corrigé de l'exercice 1 — Au-delà du risque cyber : une typologie de la sécurité de l'information

- (a) Une pièce jointe mal adressée relève de la même catégorie de risque qu'un piratage au sens du cours car les deux événements produisent la même conséquence — une exposition non autorisée d'information confidentielle — et le cours définit la sécurité de l'information par cette conséquence commune, non par l'intention de son auteur : « un rapport d'audit oublié dans un train [...] constitue tout autant [un] incident de sécurité de l'information que le piratage d'un serveur ». Le fait que la moitié des 43 % de fuites internes soit « non intentionnelle » implique que, pour ce sous-ensemble précis, le contrôle le plus pertinent est **comportemental** plutôt que technique : une négligence ou une erreur d'inattention (mauvais destinataire, document égaré) ne se prévient pas par un pare-feu ou un chiffrement, mais par la sensibilisation, la formation et des procédures de vérification — les contrôles techniques restant, eux, davantage adaptés à la moitié intentionnelle et aux incidents externes.
- (b) Les Paradise Papers, une fuite *externe* au cabinet Appleby (les journalistes ne sont pas des employés d'Appleby) obtenue par exfiltration non autorisée de données, relèvent du quadrant **Externe / Vol** (piratage et ingénierie sociale). La fuite suspectée d'un employé de l'IRS relève du quadrant **Interne / Vol**, puisque la source est interne (un employé) et l'acte intentionnel (une divulgation délibérée, non une simple erreur). Le vol de clés privées de bZx (55 millions de dollars) relève du quadrant **Externe / Vol**, un piratage classique perpétré par des attaquants extérieurs à la plateforme. Le vol de clés privées de BXH (139,2 millions de dollars) illustre une « possible complicité interne » selon le cours : il se classe donc, au moins partiellement, dans le quadrant **Interne / Vol** plutôt que dans le seul quadrant externe, la frontière entre les deux quadrants de vol pouvant se brouiller lorsque l'attaque externe est facilitée par une complicité interne.
- (c) Les cinq fonctions du NIST CSF, dans l'ordre donné par le cours, sont : **identifier, protéger, détecter, répondre, récupérer**. Une organisation qui se limiterait au seul NIST CSF perdrait l'accès aux « contrôles techniques opérationnels détaillés » du CIS — elle disposerait d'une structure conceptuelle mais d'aucune liste priorisée d'actions techniques concrètes à déployer — ainsi qu'au « chemin vers une certification externe reconnue » de l'ISO 27001, la privant de toute reconnaissance formelle et externe de sa démarche de sécurité. À l'inverse, une organisation se limitant au seul CIS disposerait de contrôles techniques précis mais d'aucune structure conceptuelle de haut niveau pour les organiser en une stratégie cohérente, ni de certification externe ; et une organisation se limitant à la seule ISO 27001 obtiendrait une certification, mais sans le détail opérationnel du CIS pour la mettre en œuvre concrètement.
- (d) Un exemple d'atteinte à la **confidentialité** sans atteinte aux deux autres dimensions : l'exfiltration silencieuse de données par un attaquant qui consulte des dossiers clients sans les modifier ni perturber la disponibilité des systèmes. Un exemple d'atteinte à l'**intégrité** seule : la modification frauduleuse d'un montant dans une base de données transactionnelle, sans que les données restent confidentielles (l'accès demeure autorisé) ni que la disponibilité du système soit affectée. Un exemple d'atteinte à la seule **disponibilité** : une attaque par déni de service qui rend un portail client inaccessible, sans qu'aucune donnée ne soit consultée ni modifiée. Le cours range la disponibilité dans le domaine de la continuité d'activité plutôt que dans la seule sécurité de l'information car protéger la disponibilité d'un service face à un sinistre (panne, catastrophe, attaque) mobilise des dispositifs de continuité (BCM, RPO, RTO) communs à toute cause de rupture de service, cybernétique ou non, alors que la confidentialité et l'intégrité sont des propriétés de l'information elle-même, protégées par des dispositifs spécifiquement dédiés à l'information — le triptyque CIA reste néanmoins présenté comme un tout car les trois dimensions sont fréquemment attaquées de façon combinée par un même incident.

- (a) Les KRI mesurant une défaillance de **processus technique** sont le retard de correctifs de vulnérabilité et le retard des tests d'intrusion; ceux mesurant une défaillance **humaine ou organisationnelle** sont le taux de résultats aux tests de phishing simulés, le nombre de récidivistes, le taux de vacance dans les équipes de cybersécurité, et le nombre d'appareils ou de cartes d'accès perdus ou volés. Un KRI est un « signal avancé » plutôt qu'une mesure de la perte elle-même car il observe une *condition préalable* à la matérialisation d'un risque — un correctif non appliqué, un taux d'échec élevé aux tests de phishing — *avant* qu'un attaquant n'exploite effectivement cette faiblesse : attendre la matérialisation d'un incident pour agir revient à découvrir la vulnérabilité au moment même où elle cause un dommage, alors que le KRI permet une action corrective en amont, quand le coût de la correction reste encore modeste.
- (b) La perte de 5 milliards de dollars représente $5/15,5 = 32,2581\%$ de la capitalisation boursière totale de 15,5 milliards de dollars. Les quatre catégories de données personnelles exfiltrées, selon le cours, sont : les noms, les dates de naissance, les numéros de sécurité sociale, et les informations de cartes bancaires. Le cours précise « pendant trois mois » avant de donner le nombre de consommateurs affectés car la durée de l'intrusion non détectée détermine directement l'ampleur de la fuite : plus les attaquants restent longtemps non détectés au sein des systèmes, plus ils ont le temps d'accéder à de nouvelles bases de données et d'exfiltrer des volumes croissants de données — le lien implicite est donc que les 147 millions de comptes affectés sont, pour une large part, la conséquence directe de ces trois mois d'accès continu plutôt que d'un accès instantané et immédiatement détecté.
- (c) L'arriéré de 8 500 vulnérabilités non corrigées détecté par l'audit de 2015 est très exactement ce que le KRI « retard de correctifs de vulnérabilité » est censé mesurer en continu : si ce KRI avait été suivi et remonté de façon régulière plutôt que découvert ponctuellement par un audit isolé, la direction d'Equifax aurait disposé d'une alerte précoce et récurrente sur la dégradation de sa posture de sécurité — au lieu d'un diagnostic ponctuel en 2015, sans suivi manifeste jusqu'à l'attaque de 2017. Le piratage du site W-2 Express en mai 2016 constitue un « précédent ignoré » particulièrement aggravant car il démontre qu'Equifax avait déjà subi, un an avant la fuite majeure, la matérialisation concrète d'une faiblesse de sécurité de nature comparable (exposition de données personnelles, 430 000 personnes touchées) : ce n'est donc pas un simple incident isolé et sans lien, mais un signal direct que les déficiences structurelles de gestion des correctifs et de sécurité de l'information restaient non corrigées, information qui aurait dû, à elle seule, déclencher une revue approfondie avant qu'une deuxième matérialisation, à une échelle bien plus grande, ne survienne.
- (d) Le retard de correctifs de vulnérabilité aurait pu signaler la deuxième faiblesse (gestion des correctifs) directement, puisqu'il en mesure exactement l'objet. Le retard des tests d'intrusion aurait pu signaler indirectement la première faiblesse (absence d'inventaire), un test d'intrusion bien mené révélant typiquement l'existence de systèmes non inventoriés ou non corrigés. Aucun des six KRI proposés par le cours ne mesure directement ni la communication interne défaillante (troisième faiblesse, un employé absent d'une liste de diffusion), ni le certificat SSL expiré (quatrième faiblesse, un défaut de surveillance technique du trafic chiffré), ni la communication de crise externe (cinquième faiblesse, un délai d'annonce publique) : ces trois faiblesses ne relèvent pas du périmètre couvert par les six KRI proposés. Cela révèle une limite importante d'un dispositif de KRI, même bien conçu : aussi pertinent soit-il pour les dimensions techniques et comportementales qu'il couvre explicitement, il ne garantit aucunement une couverture exhaustive de toutes les défaillances possibles — la gouvernance de la communication interne, la maintenance des dispositifs de surveillance technique eux-mêmes (comme un certificat SSL), et la gestion de crise externe appellent des dispositifs de contrôle et de surveillance distincts, non substituables par les seuls KRI cités.

- (a) Les cinq faiblesses sont : (i) l'**absence d'inventaire exhaustif des actifs informatiques**, qui a empêché la localisation et la correction d'Apache Struts dans le « délai réglementaire de 48 heures » suivant une alerte critique ; (ii) l'**échec de mise en œuvre de la politique de gestion des correctifs**, le correctif étant « disponible dès le 7 mars [...] distribué en interne à 400 employés — sans jamais être appliqué » ; (iii) une **communication interne défailante**, un employé au fait de l'usage d'Apache Struts n'étant pas sur la liste de diffusion, et son manager, qui l'avait reçue, ne l'ayant « pas relayée » ; (iv) un **certificat SSL expiré**, qui a empêché la surveillance du trafic chiffré et retardé la détection « jusqu'au 29 juillet » ; et (v) une **communication de crise externe défailante**, l'annonce publique n'étant intervenue que « six semaines après la découverte de la brèche ».
- (b) La part du règlement de 700 millions de dollars ne revenant pas directement aux consommateurs est $700 - 300 = 400$ millions de dollars, soit $400/700 = 57,1429\%$ du règlement total. Le choix de mentionner précisément la démission du directeur général, du RSSI et du directeur des systèmes d'information — plutôt qu'une mention générique de départs à la direction — reflète directement la nature des cinq faiblesses identifiées : le directeur des systèmes d'information porte la responsabilité de l'inventaire des actifs et de l'infrastructure technique (faiblesses 1 et 4), le RSSI porte la responsabilité de la politique de gestion des correctifs et de la communication interne de sécurité (faiblesses 2 et 3), et le directeur général porte la responsabilité ultime de la gouvernance et de la communication de crise externe (faiblesse 5) — ces trois départs couvrent ainsi, presque un pour un, l'ensemble des cinq défaillances structurelles identifiées, plutôt que de sanctionner un service ou une fonction isolée.
- (c) « A contrario » signifie ici que le cas Equifax illustre les conséquences de l'*absence* des 3R, et non leur application réussie : le cours est explicite — « une communication tardive et peu transparente a aggravé la perte de confiance ». Le délai de six semaines est en tension avec chacun des trois principes : avec le **regret**, car une reconnaissance sincère et une excuse ne peuvent produire leur effet rassurant que si elles interviennent rapidement après la découverte, un silence de six semaines laissant au contraire le public et les médias combler ce vide par la spéculation et la défiance ; avec la **raison**, car une explication transparente des causes n'a pu être communiquée pendant ces six semaines, laissant les consommateurs affectés dans l'ignorance de ce qui s'était produit et pourquoi ; avec le **remède**, car aucune solution d'indemnisation ne pouvait être proposée aux consommateurs avant que l'incident ne soit même rendu public, retardant d'autant la mise en œuvre de toute mesure réparatrice.
- (d) Deux exemples précis d'enchaînement causal entre les cinq faiblesses : premièrement, l'absence d'inventaire exhaustif (faiblesse 1) a rendu impossible l'application du correctif dans le délai de 48 heures, ce qui a directement alimenté l'échec de la politique de gestion des correctifs (faiblesse 2) — sans savoir où se trouvait Apache Struts, aucune équipe ne pouvait le corriger, quelle que soit la qualité de la politique formelle en vigueur. Deuxièmement, la communication interne défailante (faiblesse 3, l'alerte non relayée par le manager) a directement empêché la correction que la faiblesse 2 aurait pu, en théorie, encore permettre après coup : même distribué à 400 employés, le correctif n'a été appliqué par aucun d'entre eux, en partie parce que l'information n'a pas atteint la bonne personne au bon niveau de décision. Si une seule des cinq faiblesses avait été corrigée à temps, l'attaque n'aurait pas nécessairement été évitée dans son intégralité selon la logique du cours — qui insiste sur la « conjonction de défaillances » plutôt que sur une cause unique — mais elle aurait vraisemblablement été rendue moins probable ou moins grave : par exemple, un certificat SSL renouvelé (faiblesse 4 corrigée seule) n'aurait pas empêché l'intrusion initiale via Apache Struts, mais en aurait probablement raccourci la durée de trois mois à quelques semaines, limitant d'autant le volume de données exfiltrées.

2 Corrigé de l'exercice cumulatif

Corrigé de l'exercice 4 — Le cas Equifax à la lumière des quatre chapitres précédents

- (a) La deuxième faiblesse d'Equifax — un correctif « disponible dès le 7 mars [...] distribué en interne à 400 employés — sans jamais être appliqué » — est très exactement le scénario que le patch ageing du chapitre 7 est conçu pour prévenir en amont : cet indicateur mesure précisément le délai entre la disponibilité d'un correctif et son déploiement effectif, et un patch ageing suivi en continu aurait signalé, dès les premiers jours suivant le 7 mars, que ce correctif restait non appliqué alors même qu'il était déjà connu et distribué — l'attaque du 10 mars n'ayant laissé que trois jours de marge, un tel indicateur, suivi quotidiennement plutôt que découvert après coup, était la seule chance réaliste de prévenir l'exploitation de la vulnérabilité dans une fenêtre aussi courte. Ce chapitre tient la promesse du chapitre 7 au-delà du seul patch ageing en démontrant, à travers les cinq faiblesses structurelles et non la seule défaillance technique du correctif, que le « chantier encore en construction » évoqué par le chapitre 7 concerne un dispositif de résilience *complet* — inventaire des actifs, communication interne, surveillance technique (certificat SSL), et communication de crise — et non la seule dimension du patch ageing : le cas Equifax illustre ainsi que les « indicateurs prospectifs de résilience, encore peu harmonisés » du chapitre 7 doivent, pour être efficaces, couvrir l'ensemble de cette chaîne de défaillances plutôt qu'un seul maillon technique isolé.
- (b) La formule du chapitre 6 à propos de la CBA — un cadre « meilleur sur le papier qu'en pratique » — s'applique mot pour mot au cas Equifax : la politique formelle de gestion des correctifs, dont Equifax « développait alors sa toute première [version] » en 2015, existait bien « sur le papier », mais son échec d'application — le correctif jamais appliqué malgré sa distribution à 400 employés — démontre exactement le même écart entre le dispositif documenté et sa mise en œuvre effective que celui relevé par le régulateur australien pour la CBA. La troisième faiblesse de ce chapitre — l'employé absent de la liste de diffusion et le manager qui « ne l'a pas relayée » — relève davantage d'un problème **organisationnel** que d'une fonction de sécurité de l'information institutionnellement faible au sens de l'étude Ellul et Yerramilli citée au chapitre 6 : cette étude mesure la force et l'indépendance *structurelles* de la fonction risque (moyens, autorité, rattachement hiérarchique), alors que la défaillance décrite ici est un incident ponctuel de circulation de l'information au sein d'une chaîne hiérarchique par ailleurs peut-être correctement dotée — la distinction importe car un RMI élevé n'immunise pas nécessairement une organisation contre une simple erreur humaine de diffusion, qui peut survenir indépendamment de la solidité institutionnelle globale de la fonction.
- (c) La perte de 5 milliards de dollars subie par Equifax illustre, à une tout autre échelle que les exemples du chapitre 5 (le seuil de 10 millions d'euros y séparant déjà les pertes « les plus importantes »), le même principe de queue extrêmement épaisse : un raisonnement fondé sur une perte « moyenne » d'incident de sécurité de l'information — calculée, par construction, à partir de la masse des incidents mineurs et fréquents (comme les pertes de sauvegardes ou erreurs d'envoi évoquées au chapitre 8 lui-même) — n'aurait manifestement rien pu prédire d'un événement concentrant à lui seul plusieurs milliards de dollars de perte, exactement comme le chapitre 5 l'affirme : « il n'y a pas de moyennes pertinentes en risque opérationnel ». Selon la logique du « gâteau du reporting » du chapitre 5, l'arriéré de 8 500 vulnérabilités détecté en 2015 aurait dû remonter jusqu'au conseil d'administration d'Equifax, à tout le moins sous forme de « conclusion » synthétique : le chapitre 5 précise qu'un événement doit remonter au conseil dès lors qu'il « révèle une faiblesse structurelle de contrôle affectant l'appétit pour le risque de l'organisation », or un arriéré de cette ampleur, touchant l'ensemble du processus de gestion des correctifs d'une institution manipulant des données sensibles sur des centaines de millions de personnes, constitue précisément une telle faiblesse structurelle — le fait que ce signal n'ait, semble-t-il, pas produit de correction durable avant 2017 suggère que ce mécanisme de remontée au conseil, tel que théorisé par le chapitre 5, a lui-même fait défaut chez Equifax.
- (d) Le délai de six semaines viole le **regret** car une reconnaissance sincère et une excuse perdent leur crédibilité et leur effet rassurant lorsqu'elles arrivent si tardivement après la découverte des faits, laissant penser à une réticence à assumer plutôt qu'à un regret spontané ; il viole la **raison**

car aucune explication transparente des causes et des responsabilités n'a pu être fournie aux parties prenantes pendant ces six semaines, la transparence perdant une grande partie de sa valeur lorsqu'elle survient après, et non pendant, la période d'incertitude ; il viole le **remède** car aucune solution d'indemnisation concrète ne pouvait être proposée avant l'annonce publique elle-même, retardant d'autant la mise en œuvre effective de toute réparation envers les 147 millions de consommateurs concernés. La diffusion du correctif « à 400 employés — sans jamais être appliqué » correspond, des quatre niveaux de rigueur du chapitre 4, au niveau le plus faible, l'**auto-certification** (ou une forme encore plus passive, une simple diffusion d'information sans même de déclaration en retour) : personne n'a vérifié, ni par examen documentaire, ni par observation, ni par reperformance, que le correctif avait effectivement été appliqué sur les systèmes concernés. Un test de **reperformance** — au sens du chapitre 4, « reproduire le contrôle sur un échantillon et comparer les résultats » — aurait consisté, par exemple, à vérifier techniquement et directement, sur un échantillon de serveurs exposant Apache Struts, que la version corrigée était bien installée : un tel contrôle aurait très probablement révélé, dès les jours suivant la diffusion du 7 mars, que le correctif n'avait pas été appliqué, offrant encore une fenêtre d'action avant l'attaque du 10 mars.

3 Corrigé des applications en sciences économiques

Corrigé de l'exercice 5 — Chiffrer une matrice des risques de sécurité de l'information à quatre quadrants

On a quatre quadrants avec (n , perte moyenne) : Externe/Vol (14, 180 000), Externe/Perte (5, 95 000), Interne/Vol (9, 60 000), Interne/Perte (22, 15 000).

- (a) Pertes totales : Externe/Vol = $14 \times 180\,000 = 2\,520\,000$ € ; Externe/Perte = $5 \times 95\,000 = 475\,000$ € ; Interne/Vol = $9 \times 60\,000 = 540\,000$ € ; Interne/Perte = $22 \times 15\,000 = 330\,000$ €. Le nombre total d'incidents est $14 + 5 + 9 + 22 = 50$, pour une perte totale de $2\,520\,000 + 475\,000 + 540\,000 + 330\,000 = 3\,865\,000$ €. Les incidents internes (Interne/Vol + Interne/Perte) sont au nombre de $9 + 22 = 31$, soit $31/50 = 62,00\%$ du nombre total d'incidents, tandis que leur perte cumulée est $540\,000 + 330\,000 = 870\,000$ €, soit $870\,000/3\,865\,000 = 22,5097\%$ de la perte totale. En nombre d'incidents, ce portefeuille (62,00 % d'origine interne) est donc nettement **plus** exposé au risque interne que ne le suggère la moyenne sectorielle McAfee de 43 % citée par le cours — mais en valeur de perte, l'exposition interne réelle (22,5097 %) est au contraire **inférieure** à cette même moyenne : la comparaison dépend donc entièrement de l'unité de mesure retenue (nombre d'incidents ou montant de la perte).
- (b) La perte moyenne pondérée par incident est $3\,865\,000/50 = 77\,300$ €. La part du quadrant Externe/Vol dans le nombre total d'incidents est $14/50 = 28,00\%$, tandis que sa part dans la perte totale est $2\,520\,000/3\,865\,000 = 65,2005\%$. Ces deux parts sont très éloignées l'une de l'autre : le quadrant Externe/Vol, qui ne représente que 28,00 % des incidents, concentre à lui seul plus de 65 % de la perte totale — une part très disproportionnée par rapport à sa fréquence. Cet écart illustre qu'un raisonnement fondé sur la seule perte moyenne pondérée de 77 300 € masquerait entièrement cette hétérogénéité : cette moyenne ne représente la réalité d'aucun des quatre quadrants pris isolément, ni le quadrant Externe/Vol (perte moyenne réelle de 180 000 €, plus du double de la moyenne globale) ni le quadrant Interne/Perte (perte moyenne réelle de 15 000 €, plus de cinq fois inférieure à cette même moyenne).
- (c) La part du quadrant Interne/Perte dans le nombre total d'incidents est $22/50 = 44,00\%$, ce qui **dépasse** le seuil de 30 % fixé par la compagnie : la revue obligatoire des procédures de sauvegarde et de DLP est donc **déclenchée**. La part de ce même quadrant dans la perte totale est en revanche $330\,000/3\,865\,000 = 8,5382\%$: ce quadrant, bien qu'il soit le plus fréquent en nombre d'incidents, est donc très loin d'être le plus coûteux en moyenne — une nouvelle illustration, cohérente avec le (b), du décalage entre fréquence et sévérité selon les quadrants.
- (d) Avec une réduction de 30 % du nombre d'incidents dans les deux quadrants de vol intentionnel, sans changement de la perte moyenne unitaire : le nouveau nombre d'incidents Externe/Vol est

$14 \times 0,70 = 9,8$, pour une nouvelle perte de $9,8 \times 180\,000 = 1\,764\,000$ € (économie de $2\,520\,000 - 1\,764\,000 = 756\,000$ €) ; le nouveau nombre d'incidents Interne/Vol est $9 \times 0,70 = 6,3$, pour une nouvelle perte de $6,3 \times 60\,000 = 378\,000$ € (économie de $540\,000 - 378\,000 = 162\,000$ €). L'économie totale ainsi réalisée est $756\,000 + 162\,000 = 918\,000$ €, pour un bénéfice net de l'investissement de $918\,000 - 50\,000 = 868\,000$ €, soit un ratio bénéfice/coût de $918\,000/50\,000 = 18,36$ — un investissement très largement rentable. La nouvelle perte totale du portefeuille est $3\,865\,000 - 918\,000 = 2\,947\,000$ €.

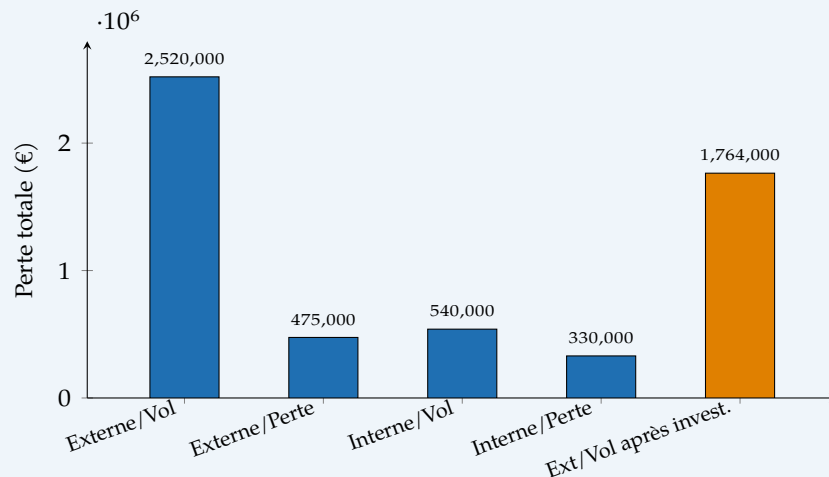


FIG. 1 : Perte totale par quadrant de la matrice de sécurité de l'information (bleu), et perte du quadrant Externe/Vol après l'investissement de 50 000 € en contrôles comportementaux réduisant son nombre d'incidents de 30 % (orange) — exercice 5.

Corrigé de l'exercice 6 — Règlement post-incident et coût du délai de détection (cas Equifax), chiffré

On a 60 millions de clients affectés, un règlement de 250 millions \$ dont 120 millions \$ d'indemnisation directe, une capitalisation boursière pré-incident de 8 milliards \$, et une perte boursière de 28 %.

- La part du règlement ne revenant pas directement aux consommateurs est $250 - 120 = 130$ millions \$. L'indemnisation moyenne par consommateur affecté est $120\,000\,000/60\,000\,000 = 2,00$ \$ par consommateur. Le plancher réglementaire théorique de 1,50 \$ par consommateur est donc **respecté**, avec une marge de 0,50 \$ par consommateur.
- La perte de capitalisation boursière est $0,28 \times 8\,000\,000\,000 = 2\,240\,000\,000$ \$ (soit 2,24 milliards \$). Le ratio de cette perte au règlement total de 250 millions \$ est $2\,240/250 = 8,96$: la perte de capitalisation boursière représente donc près de 9 fois le règlement réglementaire lui-même. Ce ratio est bien cohérent, en ordre de grandeur, avec le cas réel d'Equifax, où la perte boursière d'environ 5 milliards \$ représentait $5\,000/700 \approx 7,14$ fois le règlement de 700 millions \$ — les deux cas illustrant, dans le même ordre de grandeur (autour de 7 à 9 fois), que la sanction du marché dépasse très largement la sanction réglementaire directe.
- Le coût total d'un incident, somme du règlement et de la perte boursière du (b), est $250\,000\,000 + 2\,240\,000\,000 = 2\,490\,000\,000$ \$ (soit 2,49 milliards \$). Le coût annualisé de l'investissement de 40 millions \$ sur 3 ans est $40/3 = 13,3333$ millions \$ par an. La perte annuelle attendue avant l'investissement (probabilité 8 %) est $0,08 \times 2\,490\,000\,000 = 199\,200\,000$ \$; après l'investissement (probabilité 1,5 %), elle est $0,015 \times 2\,490\,000\,000 = 37\,350\,000$ \$. Le bénéfice annuel qui en résulte est $199\,200\,000 - 37\,350\,000 = 161\,850\,000$ \$, pour un bénéfice net annuel de $161\,850\,000 - 13\,333\,333 = 148\,516\,667$ \$ et un ratio bénéfice/coût de $161\,850\,000/13\,333\,333 = 12,1388$: l'investissement est très largement **justifié économiquement**.
- Avec un coût de base de 900 millions \$ et une majoration linéaire de 3 % par semaine de retard : un délai de 90 jours équivaut à $90/7 = 12,8571$ semaines, pour un coût total de $900\,000\,000 \times (1 + 0,03 \times 12,8571) = 900\,000\,000 \times 1,385714 = 1\,247\,142\,857$ \$. Un délai de 14 jours équivaut à 2 semaines

exactement, pour un coût total de $900\,000\,000 \times (1 + 0,03 \times 2) = 900\,000\,000 \times 1,06 = \mathbf{954\,000\,000}$ \$. L'économie réalisée en ramenant le délai de 90 à 14 jours est $1\,247\,142\,857 - 954\,000\,000 = \mathbf{293\,142\,857}$ \$, soit $293\,142\,857 / 1\,247\,142\,857 = \mathbf{23,5052\%}$ de réduction relative par rapport au coût au délai de 90 jours. Ce résultat est bien cohérent avec le rôle attribué par le cours au certificat SSL expiré d'Equifax, qui a retardé la détection de l'intrusion « jusqu'au 29 juillet », soit plus de trois mois après le début de l'attaque : ce calcul illustre chiffrément qu'un tel retard de détection, loin d'être un simple inconvénient opérationnel, peut à lui seul représenter près d'un quart du coût total d'un incident majeur de sécurité de l'information.

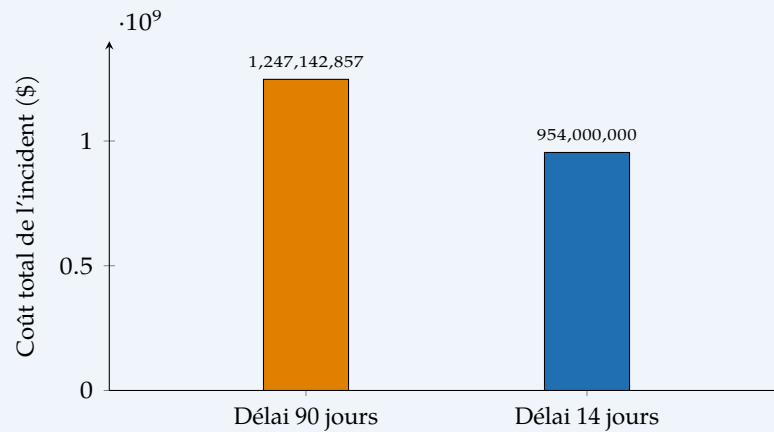


FIG. 2 : Coût total estimé d'un incident de sécurité de l'information selon le délai de détection, sous l'hypothèse d'une majoration linéaire de 3 % par semaine de retard à partir d'un coût de base de 900 millions \$: délai de 90 jours à la Equifax (orange) contre délai ramené à 14 jours par une surveillance technique fonctionnelle (bleu) — exercice 6.